16/10/26

Informe de auditoría de gobernanza y cumplimiento

ISO 27001 INTERAFAS

Andrea Morúa Bravo
MTRO. SERVANDO LÓPEZ CONTRERAS

Tabla de contenido

Alcance 2
1.1 Información institucional de INTERAFAS 2
1.2 Proyecto de implementación del SGSI ante la alta dirección 2
Referencias normativas 3
2.1 Normas internacionales de ISO 27000 3
2.2 Marco legal y regulatorio institucional en México 6
Términos y condiciones 7
Contexto de la organización 7
4.1 Activos internos 7
4.2 Activos externos 8
Liderazgo 8
5.1 Política general de seguridad de la información 8
5.2 Políticas funcionales para activos internos 9
5.3 Políticas funcionales para activos externos 11
Planificación 13
6.1 Metodología de administración del riesgo 13
6.2 Tratamiento y administración del riesgo 14
6.3 Matriz de riesgos 15
Soporte 18
7.1 Minuta del Comité Directivo sobre SGSI 18
7.2 Soporte documental y materia de prevención 19
Operación 19
8.1 Alineación con el Ciclo PDCA (Planificar, Hacer, Verificar, Actuar) 19
Matriz RACI 20
Evaluación del desempeño 21
Mejora 22

Alcance

1.1 Información institucional de INTERAFAS

- **Quiénes somos:** INTERAFAS coordina la prestación de servicios de agua potable, alcantarillado y saneamiento con un enfoque metropolitano, asegurando la continuidad operacional y la atención ciudadana.
- **Misión:** Gestionar el agua con visión metropolitana, prestando servicios esenciales mediante infraestructura, conocimiento técnico, atención ciudadana y coordinación entre municipios.
- **Visión:** Una red resiliente y meritoria que integra la operación, el mantenimiento, la información y la transparencia para sostener servicios confiables frente a cambios y contingencias.
- **Objetivos estratégicos:**
    - Servicio: Garantizar el servicio esencial y la atención ciudadana.
    - Resiliencia: Fortalecer la preparación y recuperación ante fallas.
    - Transparencia: Asegurar el acceso a la información pública.
    - Eficiencia: Implementar medición y mejora continua.
- **Historia y trayectoria institucional:**

  La infraestructura actual es resultado de casi cinco décadas de expansión urbana y modernización, destacando hitos clave como el primer sistema coordinado de abastecimiento (1978), la primera planta de tratamiento regional (1984), la interconexión de redes (1992), la automatización del bombeo principal (1998), el centro de operación hidráulica (2004), el nacimiento del organismo intermunicipal (2008), la digitalización de trámites (2021), el programa de telemetría (2023), y la consolidación del Observatorio Hídrico Metropolitano en 2026.

- **Organigrama y capital humano:**

  El organismo cuenta con un equipo directivo encabezado por el Dr. Adrián Leclerc Mendoza (Director General), Ing. Elena Marín Soler (Operación Hidráulica), Ing. Gabriel Monteiro Vega (Saneamiento), Mtra. Laura Bianchi Romero (Tecnologías e Innovación), Lic. Marc Dubois Hernández (Jurídico), C.P. Sofía Costa Navarro (Administrativa), Lic. Daniel Moreau Salazar (Atención Ciudadana) e Ing. Isabelle Laurent Castro (Monitoreo Operacional). La fuerza laboral operativa asciende a 486 colaboradores distribuidos en Operación (238), Ingeniería y tecnología (74), Administración (72), Atención ciudadana (58), Dirección y coordinación (26) y Jurídico y cumplimiento (18).

1.2 Proyecto de implementación del SGSI ante la alta dirección

El presente proyecto de implantación del Sistema de Gestión de Seguridad de la Información (SGSI) bajo la norma **ISO/IEC 27001** se ejecutará de forma directa en la **Dirección de Tecnologías e Innovación**, en coordinación transversal con la **Dirección**

de Operación Hidráulica y el **Centro de Operación Hidráulica**. El alcance de la auditoría y certificación comprende la infraestructura tecnológica de procesamiento, las redes de telemetría, los portales de atención ciudadana y los repositorios de información institucional para proteger los servicios críticos frente a riesgos cibernéticos y operacionales.

Referencias normativas

Para garantizar el cumplimiento legal, regulatorio y contractual que compete a la institución, el SGSI de INTERAFAS se alinea con el siguiente marco normativo:

2.1 Normas internacionales de ISO 27000

De las normas publicadas oficialmente por la Organización Internacional de Normalización (ISO) y la Comisión Electrotécnica Internacional (IEC) dentro de la serie 27000, se seleccionan e integran aquellas de interés directo para la gobernanza, seguridad de la tecnología, ciberseguridad industrial y protección de datos de INTERAFAS:

1. **ISO/IEC 27000** - Information security management systems — Overview and vocabulary (Fundamentos y vocabulario).
2. **ISO/IEC 27001** - Information security, cybersecurity and privacy protection — Information security management systems — Requirements (Requisitos del SGSI).
3. **ISO/IEC 27002** - Information security, cybersecurity and privacy protection — Information security controls (Código de buenas prácticas para controles de seguridad).
4. **ISO/IEC 27003** - Information security management systems — Guidance on ISO/IEC 27001 implementation (Guía de implementación).
5. **ISO/IEC 27004** - Information security management — Monitoring, measurement, analysis and evaluation (Monitoreo, medición y análisis de desempeño).
6. **ISO/IEC 27005** - Information security, cybersecurity and privacy protection — Guidance on managing information security risks (Gestión y tratamiento de riesgos de seguridad).
7. **ISO/IEC 27006** - Requirements for bodies providing audit and certification of information security management systems (Requisitos para entidades de auditoría y certificación).
8. **ISO/IEC 27007** - Guidelines for information security management systems auditing (Directrices para la auditoría de sistemas de gestión).

9. **ISO/IEC 27008** - Guidelines for the assessment of technical information security controls (Evaluación técnica de controles de seguridad).
10. **ISO/IEC 27009** - Sector-specific application of ISO/IEC 27001 — Requirements (Aplicación sectorial de requisitos).
11. **ISO/IEC 27010** - Information security — Management for inter-sector and inter-organizational communications (Seguridad en comunicaciones interorganizacionales y críticas).
12. **ISO/IEC 27011** - Information security management guidelines for telecommunications organizations (Seguridad para organizaciones de telecomunicaciones).
13. **ISO/IEC 27013** - Guidance on the integrated implementation of ISO/IEC 27001 and ISO/IEC 20k (Implementación integrada con gestión de servicios TI).
14. **ISO/IEC 27014** - Governance of information security (Gobierno de la seguridad de la información).
15. **ISO/IEC 27015** - Information security management guidelines for financial services (Directrices de seguridad aplicadas a servicios financieros y transacciones).
16. **ISO/IEC 27017** - Code of practice for information security controls based on ISO/IEC 27002 for cloud services (Seguridad en servicios en la nube).
17. **ISO/IEC 27018** - Code of practice for protection of personally identifiable information (PII) in public clouds (Protección de datos personales en nubes públicas).
18. **ISO/IEC 27019** - Information security controls for the energy utility industry (Seguridad de la información para procesos de control en suministros e infraestructura crítica de servicios públicos).
19. **ISO/IEC 27021** - Competence requirements for information security management system auditors (Competencia para auditores de SGSI).
20. **ISO/IEC 27031** - Guidelines for information and communication technology readiness for business continuity (Preparación de las TICs para la continuidad del negocio).
21. **ISO/IEC 27032** - Guidelines for cybersecurity (Directrices generales de ciberseguridad).
22. **ISO/IEC 27033-1** - Network security — Overview and concepts (Seguridad en redes: Visión general y conceptos).
23. **ISO/IEC 27033-2** - Guidelines for the design and implementation of network security (Diseño e implementación de seguridad en redes).

24. **ISO/IEC 27033-3** - Reference networking scenarios — Threats, design techniques and security controls (Escenarios de referencia de redes y amenazas).
25. **ISO/IEC 27033-4** - Security of communications between networks using security gateways (Seguridad en pasarelas de red y gateways).
26. **ISO/IEC 27033-5** - Securing communications across wireless networks (Seguridad en comunicaciones inalámbricas).
27. **ISO/IEC 27034-1** - Application security — Overview and concepts (Seguridad de aplicaciones: Conceptos generales).
28. **ISO/IEC 27035-1** - Information security incident management — Principles of incident management (Principios de gestión de incidentes de seguridad).
29. **ISO/IEC 27035-2** - Guidelines to plan and respond to incidents (Planificación y respuesta ante incidentes).
30. **ISO/IEC 27036-1** - Information security for supplier relationships — Overview (Seguridad de la información en la relación con proveedores).
31. **ISO/IEC 27036-2** - Requirements for supplier relationships (Requisitos para la gestión de proveedores).
32. **ISO/IEC 27036-3** - Guidelines for security of information and communication technology supply chain (Seguridad en la cadena de suministro TIC).
33. **ISO/IEC 27037** - Guidelines for identification, collection, acquisition and preservation of digital evidence (Adquisición y preservación de evidencia digital forense).
34. **ISO/IEC 27038** - Specification for digital redaction (Especificación para la supresión y enmascaramiento digital de datos).
35. **ISO/IEC 27039** - Selection, deployment and operations of intrusion detection and prevention systems (IDS/IPS).
36. **ISO/IEC 27040** - Storage security (Seguridad en sistemas de almacenamiento de datos).
37. **ISO/IEC 27041** - Guidance on assuring suitability and adequacy of incident investigative methods (Adecuación de métodos de investigación de incidentes).
38. **ISO/IEC 27042** - Guidelines for the analysis and interpretation of digital evidence (Análisis e interpretación de evidencias digitales).
39. **ISO/IEC 27043** - Incident investigation principles and processes (Principios y procesos de investigación de incidentes).

40. **ISO/IEC 27050-1** - Electronic discovery — Overview and concepts (Descubrimiento electrónico y gestión de datos legales).
41. **ISO/IEC 27070** - Security requirements for establishing root of trust (Requisitos de seguridad para raíz de confianza).
42. **ISO/IEC 27100** - Cybersecurity — Overview and concepts (Visión general de la ciberseguridad).
43. **ISO/IEC 27102** - Guidelines for cyber-insurance (Directrices para seguros cibernéticos y gestión de riesgos financieros).
44. **ISO/IEC 27701** - Extension to ISO/IEC 27001 and ISO/IEC 27002 for privacy information management (Extensión de gestión de información de privacidad y PIMS).
45. **ISO 27799** - Health informatics — Information security management in health using ISO/IEC 27002 (Adaptado analógicamente a la gestión de continuidad y seguridad operativa en servicios esenciales a la comunidad).

2.2 Marco legal y regulatorio institucional en México

Además del estándar internacional, INTERAFAS sujeta su operación normativa y de cumplimiento a los siguientes ordenamientos legales vigentes:

- **Constitución Política de los Estados Unidos Mexicanos:**
    - *Artículo 4°:* Derecho humano al acceso, disposición y saneamiento de agua para consumo personal y doméstico en forma suficiente, salubre, aceptable y asequible.
    - *Artículo 6°:* Derecho a la protección de datos personales, acceso a la información pública y transparencia gubernamental.
- **Leyes Federales y Estatales de Transparencia:**
    - **Ley General de Transparencia y Acceso a la Información Pública** y la Ley Estatal en la materia, obligando al resguardo seguro de portales y portales de datos abiertos.
- **Protección de Datos Personales:**
    - **Ley General de Protección de Datos Personales en Posesión de Sujetos Obligados**, regulando el tratamiento de los padrones de usuarios y expedientes ciudadanos.
- **Normativa Hidráulica y de Infraestructura Crítica:**
    - **Ley de Aguas Nacionales** y marcos regulatorios locales para la coordinación intermunicipal de organismos operadores de agua.

- **Estándares de Seguridad de Transacciones Financieras:**
    - **PCI-DSS (Payment Card Industry Data Security Standard)** para la regulación de pasarelas de pago y portales de cobro de recibos ciudadanos.

Términos y condiciones

Para efectos de conceptualización y alineación con la Alta Dirección de INTERAFAS, se definen los siguientes 5 términos críticos basados en la norma ISO/IEC 27001:

1. **Activo de información:** Todo aquello que tiene valor para la organización y que, por lo tanto, debe ser protegido, incluyendo bases de datos, documentación técnica, software, equipos de cómputo y talento humano.
2. **Amenaza:** Causa potencial de un incidente indeseado, la cual puede provocar daños a un sistema, activo u organización (ej. fallas de telemetría, accesos no autorizados, ataques de denegación de servicio).
3. **Vulnerabilidad:** Debilidad de un activo o control que puede ser explotada por una o más amenazas para comprometer la seguridad de la información.
4. **Riesgo:** Efecto de la incertidumbre sobre los objetivos de seguridad, medido en términos de la combinación de la probabilidad de ocurrencia de un evento y el impacto asociado.
5. **Tratamiento del riesgo:** Proceso para modificar el riesgo, el cual incluye la selección e implementación de controles de seguridad destinados a mitigar, aceptar, evitar o transferir dicho riesgo.

Contexto de la organización

4.1 Activos internos

AI-01: Base de datos principal del Padrón de Usuarios y Consumos.

AI-02: Servidores y pasarelas de red del Centro de Operación Hidráulica (RTUs/PLCs).

AI-03: Infraestructura de servidores web y repositorios de código fuente de los portales internos.

AI-04: Registros de telemetría y variables operativas de los 51 pozos profundos y 31 tanques.

AI-05: Expedientes administrativos, folios y trámites ciudadanos internos.

AI-06: Padrón interno de gestión y contratación de proveedores.

AI-07: Estaciones de trabajo y equipos portátiles del personal técnico y administrativo (486 usuarios).

AI-08: Redes de interconexión municipal y fibra óptica de transmisión de datos operacionales.

AI-09: Planos topográficos, cartografía digital y sistemas de información geográfica (SIG) de la red hidráulica.

AI-10: Políticas internas, minutas del comité directivo y documentación del SGSI.

4.2 Activos externos

AE-01: Portal Ciudadano en línea (trámites, reportes, pagos y facturación digital).

AE-02: Proveedores de servicios de nube y alojamiento de sistemas externos.

AE-03: Canales digitales de atención ciudadana (redes sociales y pasarelas de comunicación).

AE-04: Pasarelas de pago bancarias y transacciones electrónicas externas.

AE-05: Proveedores de mantenimiento de infraestructura de bombeo y plantas de tratamiento.

AE-06: Observatorio Hídrico Metropolitano (datos públicos e indicadores abiertos).

AE-07: APIs públicas e integración con servicios de consulta de transparencia.

AE-08: Redes de comunicación de proveedores de telecomunicaciones y enlaces carrier externos.

AE-09: Proveedores de insumos químicos y equipos de laboratorio para las Plantas de Tratamiento.

AE-10: Marcos normativos, auditorías externas y entes fiscalizadores gubernamentales.

Liderazgo

5.1 Política general de seguridad de la información

La Dirección General de INTERAFAS establece el compromiso firme de proteger la confidencialidad, integridad y disponibilidad de la información y de la infraestructura crítica de agua potable, alcantarillado y saneamiento. La organización se compromete a cumplir con los requisitos legales y reglamentarios aplicables, gestionar de manera proactiva los riesgos tecnológicos y operativos, fomentar una cultura de ciberseguridad en los 486 colaboradores y garantizar la mejora continua del Sistema de Gestión de Seguridad de la Información (SGSI).

5.2 Políticas funcionales para activos internos

Para AI-01 (Base de datos de usuarios):

- *Estándar:* Cifrado AES-256 en reposo y en tránsito.
- *Directriz:* Prohibición absoluta de exportación masiva sin autorización de la Dirección de Tecnologías.
- *Procedimiento:* Ejecución de respaldos incrementales diarios y respaldos completos semanales aislados.
- *Línea Base:* Contraseñas de acceso a bases de datos con longitud mínima de 14 caracteres y rotación obligatoria cada 90 días.

Para AI-02 (Servidores y pasarelas RTU/PLC):

- *Estándar:* Segmentación estricta de redes IT y OT (Redes Industriales).
- *Directriz:* Ningún dispositivo de control industrial debe estar expuesto directamente a internet sin pasarela segura (VPN/Firewall perimetral).
- *Procedimiento:* Protocolo de actualización de firmware mediante verificación de firmas digitales criptográficas y validación en entorno de pruebas.
- *Línea Base:* Deshabilitación de servicios y puertos de red no utilizados en los controladores (Telnet, FTP antiguo).

Para AI-03 (Servidores web y código fuente):

- *Estándar:* Ciclo de Vida de Desarrollo Seguro (SDL) y análisis estático de vulnerabilidades.
- *Directriz:* Eliminación obligatoria de artefactos de despliegue, archivos .env, .bak y comentarios de depuración antes de liberar a producción.
- *Procedimiento:* Gestión de versiones mediante control de código fuente seguro (Git) con revisión obligatoria por pares.
- *Línea Base:* Configuración de servidores web sin listado de directorios (*Indexes* desactivados) y ocultación de versiones de software (*ServerTokens Prod*).

Para AI-04 (Variables operativas y telemetría):

- *Estándar:* Integridad de datos de sensores mediante protocolos seguros (MQTT/TLS).
- *Directriz:* Validación estricta de rangos de operación en los puntos de entrada de datos para evitar inyección de comandos o valores anómalos.
- *Procedimiento:* Monitoreo continuo de alarmas en el Centro de Operación Hidráulica ante desviaciones de presión o caudal.
- *Línea Base:* Registro de auditoría inmutable de todas las acciones de control manual sobre estaciones de bombeo.

Para AI-05 (Expedientes administrativos y trámites):

- *Estándar:* Control de acceso basado en roles (RBAC) y atributos (ABAC).

- *Directriz:* Restricción de lectura de expedientes ciudadanos exclusivamente al personal autorizado y vinculado al trámite.
- *Procedimiento:* Revocación inmediata de credenciales de acceso ante baja o cambio de adscripción del personal.
- *Línea Base:* Trazabilidad mediante registros de auditoría (*logs*) de cada visualización de expedientes sensibles.

Para AI-06 (Padrón de proveedores y contrataciones):

- *Estándar:* Validación cruzada de integridad relacional en contratos y padrones.
- *Directriz:* Prohibición de validar vínculos contractuales sin confirmación de llave foránea en base de datos.
- *Procedimiento:* Auditoría semestral de los registros de proveedores vigentes en el área jurídica y administrativa.
- *Línea Base:* Autenticación multifactor (MFA) obligatoria para el personal administrativo que modifique el padrón.

Para AI-07 (Estaciones de trabajo y equipos portátiles):

- *Estándar:* Protección de Endpoints mediante EDR (Endpoint Detection and Response) y cifrado de disco (BitLocker/FileVault).
- *Directriz:* Queda prohibido el almacenamiento de bases de datos o padrones de usuarios en equipos locales no autorizados.
- *Procedimiento:* Escaneo automático semanal de malware y actualizaciones automáticas de parches de sistema operativo.
- *Línea Base:* Bloqueo automático de sesión tras 10 minutos de inactividad.

Para AI-08 (Redes de interconexión y fibra óptica):

- *Estándar:* Redundancia y alta disponibilidad en enlaces de transmisión de datos críticos.
- *Directriz:* Cifrado de capa de enlace o túneles VPN IPsec para el tráfico de telemetría entre municipios.
- *Procedimiento:* Pruebas trimestrales de conmutación por error (*failover*) en enlaces de comunicaciones.
- *Línea Base:* Monitoreo de latencia y disponibilidad de red mediante SNMPv3.

Para AI-09 (Cartografía digital y sistemas SIG):

- *Estándar:* Resguardo y control de versiones de planos geoespaciales de infraestructura hidráulica.
- *Directriz:* Clasificación de la red de agua como infraestructura de criticidad alta; acceso restringido al área técnica.
- *Procedimiento:* Copias de seguridad mensuales de bases de datos geográficas.
- *Línea Base:* Restricción de permisos de escritura a especialistas cartográficos certificados.

Para AI-10 (Documentación del SGSI y normativas):

- *Estándar:* Control formal de versiones y aprobación por la Alta Dirección.
- *Directriz:* Toda política o procedimiento debe ser revisado al menos una vez al año.
- *Procedimiento:* Registro y distribución controlada de manuales de seguridad a los responsables de área.
- *Línea Base:* Almacenamiento en repositorio centralizado con control estricto de permisos de lectura y escritura.

5.3 Políticas funcionales para activos externos

Para AE-01 (Portal Ciudadano en línea):

- *Estándar:* OWASP Top 10 mitigación activa y validación estricta de entradas (*Input Sanitization*).
- *Directriz:* Aplicación de codificación de salida (*Output Encoding*) para prevenir vulnerabilidades de XSS e Inyección SQL.
- *Procedimiento:* Pruebas de penetración externas bianuales sobre los portales expuestos a internet.
- *Línea Base:* Implementación de cabeceras de seguridad HTTP robustas (CSP, HSTS, X-Frame-Options).

Para AE-02 (Proveedores de servicios de nube):

- *Estándar:* Acuerdos de Nivel de Servicio (SLA) y cláusulas obligatorias de seguridad de la información.
- *Directriz:* Auditoría previa de cumplimiento normativo (certificaciones ISO 27001 / SOC 2) de los proveedores de nube.
- *Procedimiento:* Revisión anual de los controles de seguridad gestionados por terceros.
- *Línea Base:* Aislamiento lógico de los entornos de INTERAFAS en la nube mediante nubes privadas virtuales (VPC).

Para AE-03 (Canales digitales de atención ciudadana):

- *Estándar:* Protocolos de verificación de autenticidad en redes sociales y canales oficiales.
- *Directriz:* Queda prohibido compartir información personal o financiera de usuarios a través de redes sociales abiertas.
- *Procedimiento:* Protocolo de respuesta y contención ante suplantación de identidad (*phishing*) institucional.
- *Línea Base:* Uso exclusivo de cuentas corporativas verificadas con doble factor de autenticación.

Para AE-04 (Pasarelas de pago bancarias externas):

- *Estándar:* Cumplimiento del estándar internacional PCI-DSS para el manejo de transacciones financieras.
- *Directriz:* INTERAFAS no debe almacenar datos completos de tarjetas de crédito o CVV en sus servidores locales.
- *Procedimiento:* Conciliación diaria automatizada de pagos y revalidación de montos en pasarela segura.
- *Línea Base:* Uso de tokens de pasarela de pago cifrados mediante HTTPS/TLS 1.3.

Para AE-05 (Proveedores de mantenimiento industrial):

- *Estándar:* Acuerdos de confidencialidad (NDA) obligatorios para personal técnico externo.
- *Directriz:* Supervisión en sitio por personal de INTERAFAS durante labores de mantenimiento en áreas críticas.
- *Procedimiento:* Registro de ingresos, salidas y acreditación de identidad de técnicos externos en plantas de bombeo.
- *Línea Base:* Restricción de acceso físico temporal y limitado a zonas operacionales específicas.

Para AE-06 (Observatorio Hídrico Metropolitano):

- *Estándar:* Anonimización y filtrado de datos operativos antes de su publicación pública.
- *Directriz:* Los indicadores públicos no deben exponer topologías de red, fabricantes ni direcciones IP internas.
- *Procedimiento:* Validación previa de reportes estadísticos por la Dirección de Tecnologías.
- *Línea Base:* Publicación de datos agregados en formatos abiertos seguros.

Para AE-07 (APIs públicas de consulta):

- *Estándar:* Limitación de tasa de peticiones (*Rate Limiting*) para evitar ataques de denegación de servicio.
- *Directriz:* Control estricto de autorización a nivel de objeto (BOLA) en cada endpoint de API expuesto.
- *Procedimiento:* Registro y monitoreo de anomalías en el consumo de las APIs públicas.
- *Línea Base:* Documentación formal y validación de esquemas de entrada (JSON Schema) en pasarelas API.

Para AE-08 (Proveedores de telecomunicaciones y enlaces):

- *Estándar:* Garantía de disponibilidad y canales dedicados (*MPLS / VPN carrier*).
- *Directriz:* Establecimiento de rutas de respaldo automáticas ante la caída del proveedor primario.

- *Procedimiento:* Reporte inmediato de incidencias de conectividad al centro de control del proveedor.
- *Línea Base:* Monitoreo sintético 24/7 de la conectividad de los enlaces externos.

Para AE-09 (Proveedores de insumos químicos para tratamiento):

- *Estándar:* Verificación de calidad y certificaciones de proveedores de productos químicos.
- *Directriz:* Control de inventarios y trazabilidad de entregas en plantas potabilizadoras y de tratamiento.
- *Procedimiento:* Recepción y análisis de certificados de calidad por lote químico.
- *Línea Base:* Almacenamiento seguro bajo normas de protección civil de sustancias químicas.

Para AE-10 (Marcos normativos y auditores externos):

- *Estándar:* Transparencia y facilitación de evidencias para auditorías de cumplimiento.
- *Directriz:* Resguardo seguro de reportes de auditoría y planes de acción correctiva.
- *Procedimiento:* Asignación de un oficial de cumplimiento para la atención de auditores externos.
- *Línea Base:* Entrega de información bajo controles estrictos de confidencialidad y cadena de custodia.

Planificación

6.1 Metodología de administración del riesgo

Para la gestión de riesgos de seguridad de la información en INTERAFAS, se adopta un enfoque cualitativo calibrado bajo métricas estandarizadas inspiradas en el Sistema de Puntuación de Vulnerabilidades Comunes (**CVSS**). La evaluación se estructura mediante una matriz de 5x5, donde se cruzan dos ejes fundamentales: **Probabilidad** (frecuencia o posibilidad de ocurrencia de la amenaza) e **Impacto** (consecuencia sobre los activos y la operación metropolitana).

El nivel de riesgo resultante se obtiene multiplicando ambos factores (Riesgo = Probabilidad * Impacto), generando un valor escala del 1 al 25:

Rango 1 - 6 (Bajo / Aceptable): El riesgo puede aceptarse mediante monitoreo rutinario.

Rango 8 - 12 (Medio / Tolerable): Requiere controles compensatorios y planificación de mitigación.

Rango 15 - 16 (Alto / Inaceptable sin control): Requiere atención prioritaria y tratamiento a corto plazo.

Rango 20 - 25 (Crítico): Requiere parada de procesos, mitigación inmediata y supervisión directa de la Alta Dirección.

Probabilidad / Impacto	**1 (Muy Bajo)**	**2 (Bajo)**	**3 (Medio)**	**4 (Alto)**	**5 (Crítico / Máximo)**
5 (Muy Alta / Certeza)	5	10	15	20	**25 (Crítico Máximo)**
4 (Alta)	4	8	12	16	20
3 (Media)	3	6	9	12	15
2 (Baja)	2	4	6	8	10
1 (Muy Baja / Rara)	1	2	3	4	5

(Menos probable / menos impacto hacia la esquina inferior izquierda; más probable / más impacto hacia la esquina superior derecha de valor 25).

6.2 Tratamiento y administración del riesgo

Una vez evaluado el riesgo en la matriz 5x5, la administración del mismo se define mediante cuatro opciones estratégicas de tratamiento:

1. **Mitigar / Reducir:** Aplicar controles técnicos y normativos del Anexo A de la norma ISO 27001 para disminuir la probabilidad o el impacto.
2. **Aceptar:** Asumir el riesgo cuando el costo de mitigación supera el daño potencial y el nivel es residual (Bajo).
3. **Evitar:** Cancelar la actividad o el componente tecnológico que genera el riesgo inaceptable.
4. **Transferir:** Compartir o transferir el impacto financiero mediante pólizas de seguros o acuerdos de nivel de servicio (SLA) con terceros.

6.3 Matriz de riesgos

ID Activo	Activo / Componente Fijo	Amenaza Identificada	Probabilidad (1-5)	Impacto (1-5)	Resultado	Nivel de Riesgo	Tratamiento y Decisión de Administración
AI-01	Base de datos Padrón de Usuarios	Exfiltración de datos personales por vulnerabilidad en consulta.	3	4	12	**Medio**	**Mitigar:** Cifrado AES-256 y control estricto de accesos DBA.
AI-02	Servidores y Pasarelas RTU/PLC (OT)	Explotación de vulnerabilidad tipo 0-Day en firmware industrial.	4	4	16	**Alto**	**Mitigar:** Segmentación estricta IT-OT y validación de parches.
AI-03	Servidores web y código fuente	Exposición de archivos de respaldo (.bak) y código vulnerable.	4	4	16	**Alto**	**Mitigar:** Purgado automático de artefactos en CI/CD y hardening web.
AI-04	Sistema de Telemetría (Pozos/Tanques)	Falsificación de variables operativas de presión y caudal.	3	4	12	**Medio**	**Mitigar:** Validación de rangos lógicos (*Safety Bounds*) en backend.
AI-05	Módulo de Expedientes Ciudadanos	Acceso no autorizado a expedientes de terceros (IDOR/BOLA).	4	4	16	**Alto**	**Mitigar:** Control estricto de propiedad de objetos en servidor.

AI-06	Padrón de Proveedores y Contrataciones	Escalamiento vertical por manipulación de rol en cliente.	3	4	12	**Medio**	**Mitigar:** Almacenamiento de roles en sesión de servidor (no en cookies).
AI-07	Computadoras de escritorio y portátiles	Infección por malware o ransomware por falta de actualización.	4	3	12	**Medio**	**Mitigar:** Actualización automatizada de parches y despliegue de EDR.
AI-08	Redes de interconexión y fibra óptica	Interrupción de enlaces de comunicación municipal.	2	4	8	**Medio**	**Transferir/Mitigar:** Enlaces redundantes con respaldo carrier (SLA).
AI-09	Cartografía digital y Sistemas SIG	Corrupción o modificación no autorizada de planos de red.	2	3	6	**Bajo**	**Aceptar/Mitigar:** Restricción de permisos y respaldos mensuales.
AI-10	Documentación y Políticas del SGSI	Pérdida u obsolescencia de manuales de gobernanza.	2	3	6	**Bajo**	**Mitigar:** Repositorio centralizado con control de versiones.
AE-01	Portal Ciudadano en línea	Ataques de denegación de servicio (DDoS) o Stored XSS.	4	4	16	**Alto**	**Mitigar:** Protección WAF perimetral y codificación de salidas.

AE-02	Proveedores de servicios en nube (Hosting)	Fuga de información alojada en infraestructura de terceros.	2	4	8	**Medio**	**Transferir:** Exigir certificaciones SOC 2 / ISO 27001 mediante contrato.
AE-03	Canales digitales de atención ciudadana	Suplantación de identidad institucional (*phishing* en redes).	3	2	6	**Bajo**	**Mitigar:** Verificación oficial de cuentas corporativas.
AE-04	Pasarelas de pago bancarias externas	Fraude en liquidación de recibos por manipulación de montos.	3	5	15	**Alto**	**Mitigar:** Revalidación estricta de saldos en servidor por ID de factura.
AE-05	Proveedores de mantenimiento industrial	Acceso físico no autorizado a estaciones de bombeo.	3	3	9	**Medio**	**Mitigar:** Acompañamiento obligatorio y bitácora de control de accesos.
AE-06	Observatorio Hídrico Metropolitano	Divulgación accidental de topología interna en APIs públicas.	3	3	9	**Medio**	**Mitigar:** Filtrado de metadatos de diagnóstico en respuestas JSON.
AE-07	APIs públicas de consulta	Explotación de endpoints no documentados u	4	3	12	**Medio**	**Mitigar:** Inventario estricto de APIs y restricción de

		ocultos (*legacy*).					métodos HTTP.
AE-08	Proveedores de telecomunicaciones externos	Caída prolongada de conectividad externa.	2	3	6	**Bajo**	**Transferir:** Establecer penalizaciones por incumplimiento de SLA.
AE-09	Proveedores de insumos químicos	Ingreso de lotes de químicos defectuosos o alterados.	2	3	6	**Bajo**	**Mitigar:** Certificados de calidad y análisis previos a descarga.
AE-10	Marcos normativos y entes fiscalizadores	Incumplimiento legal regulatorio o filtración de auditorías.	2	4	8	**Medio**	**Mitigar:** Oficial de cumplimiento y repositorio de evidencias cifrado.

Soporte

7.1 Minuta del Comité Directivo sobre SGSI

Organización: Organismo Intermunicipal de Agua y Saneamiento — **INTERAFAS**

Documento: Acta de Reunión del Comité Directivo de Seguridad de la Información

Fecha de sesión: 10 de octubre de 2026.

Lugar: Sala de Juntas de la Dirección General de INTERAFAS.

Participantes: Dr. Adrián Leclerc Mendoza (Director General), Directores de Área y Mtra. Laura Bianchi Romero (Directora de Tecnologías e Innovación / Oficial de Seguridad).

Objetivos de la Sesión:

- Presentar formalmente el diagnóstico de riesgos y vulnerabilidades del Sistema de Gestión de Seguridad de la Información (SGSI) bajo la norma ISO/IEC 27001.
- Definir los planes de acción para mitigar brechas críticas detectadas en portales web, bases de datos y pasarelas de control industrial.

Acuerdos Establecidos:

- Acuerdo 01/2026: Se aprueba por unanimidad la asignación de recursos técnicos y presupuestales para la actualización de pasarelas de control industrial y la implementación de cifrado en bases de datos.
- Acuerdo 02/2026: Se instruye a la Dirección de Atención Ciudadana y Comunicación Social difundir las campañas de concientización y los materiales preventivos (infografías y guías de contraseñas) a los 486 colaboradores del organismo.
- Acuerdo 03/2026: Se establece la obligatoriedad de realizar revisiones trimestrales del cumplimiento de la matriz de riesgos por parte de los titulares de cada área.

_____	_____	_____
Director General	Directora de Operación Hidráulica	Director de saneamiento
_____	_____	_____
Directora de IT	Director Jurídico	Directora administrativa

7.2 Soporte documental y materia de prevención



Operación

8.1 Alineación con el Ciclo PDCA (Planificar, Hacer, Verificar, Actuar)

La operación del SGSI en INTERAFAS se rige bajo la mejora continua del ciclo PDCA:

- **Planificar (Plan):** Establecer las políticas funcionales, el inventario de activos y la matriz de administración de riesgos (Secciones 4, 5 y 6).
- **Hacer (Do):** Implementar los controles de seguridad del Anexo A, los programas de concientización y la minuta de soporte directivo (Sección 7).
- **Verificar (Check):** Ejecutar auditorías internas mediante listas de verificación para medir el cumplimiento real frente al estándar ISO 27001 (Sección 9).
- **Actuar (Act):** Tomar acciones correctivas, rediseñar soportes de prevención y actualizar políticas funcionales ineficientes (Sección 10).

Matriz RACI

Roles / Procesos del SGSI	Dirección General	Dir. Tecnologías e Innovación	Dir. Operación Hidráulica	Dir. de Saneamiento	Dir. Jurídico y Cumplimiento	Dir. Atención Ciudadana
Aprobación de Políticas de Seguridad	**A**	**R**	C	C	C	I
Gestión de Riesgos y Matriz	I	**R / A**	C	C	C	I
Seguridad en Redes Industriales (IT-OT)	I	**R**	**A**	C	I	I
Gestión de Respaldos y Continuidad	I	**R / A**	C	C	I	I
Atención de Incidentes de Ciberseguridad	I	**R / A**	C	C	C	I
Cumplimiento Legal y Privacidad de Datos	A	C	I	I	**R / A**	C

Concienciación y Capacitación del Personal	I	**R**	C	C	C	**A**

R = Responsible / Realiza; A = Accountable / Aprueba; C = Consulted / Consulta; I = Informed / Informado).

Evaluación del desempeño

Para determinar el cumplimiento y funcionamiento operativo del proyecto SGSI, se implementan las siguientes listas de verificación:

ID Control	Cuestionario de Auditoría / Requisito ISO 27001	Cumple (Sí / No)	Observaciones del Auditor / Hallazgo
CHK-01	¿Se encuentran cifradas las bases de datos principales con algoritmos robustos en reposo?	**Sí**	Cifrado AES-256 implementado correctamente.
CHK-02	¿Están prohibidos y bloqueados los listados de directorios y archivos .bak en servidores web?	**No**	Se detectaron respaldos históricos expuestos en el webroot (transparencia.php.bak).
CHK-03	¿Se valida la autorización a nivel de objeto (BOLA) en todas las APIs de consulta?	**No**	Ausencia de validación de propiedad en endpoint de historial de servicios.
CHK-04	¿Se encuentra segmentada físicamente o lógicamente la red IT de la red industrial OT?	**Sí**	Segmentación operativa activa en estaciones de bombeo.
CHK-05	¿Se valida obligatoriamente una firma digital criptográfica en las actualizaciones de firmware?	**No**	El instalador verificaba únicamente sumas hash sin firma de emisor, usando SHA-1 débil.
CHK-06	¿Se ejecutan revisiones trimestrales de privilegios y accesos administrativos?	**Sí**	Bitácoras de revisión de cuentas al día por la Dirección de TI.

CHK-07	¿Han completado la capacitación en ciberseguridad el 100% del personal operativo?	**No**	Avance actual del 85%; pendiente personal de turnos nocturnos en plantas.

Mejora

Tomando como base los resultados no conformes del checklist de auditoría anterior, se ejecutan las siguientes acciones correctivas de mejora continua:

1. **Rediseño del soporte de prevención:**



2. **Mejora y actualización de la política funcional ineficiente (Política de Actualización de Firmware y Criptografía):**
   Acción: La política funcional asociada a los servidores y pasarelas de red industrial (Activo AI-02 / AE-07) es formalmente reformada. Se elimina de manera definitiva el uso de funciones hash obsoletas (como SHA-1) y se establece como mandato normativo inquebrantable el uso de **Infraestructura de Clave Pública (PKI) con firmas digitales basadas en RSA-2048 y SHA-256**, garantizando que ningún dispositivo acepte paquetes de actualización sin la firma verificada del fabricante, cerrando por completo la brecha detectada en la auditoría ofensiva.